Not If, but When: The Risk to Critical Data with AI

Kellyn Gorman

Engineer and Advocate, Redgate

redgate | About me

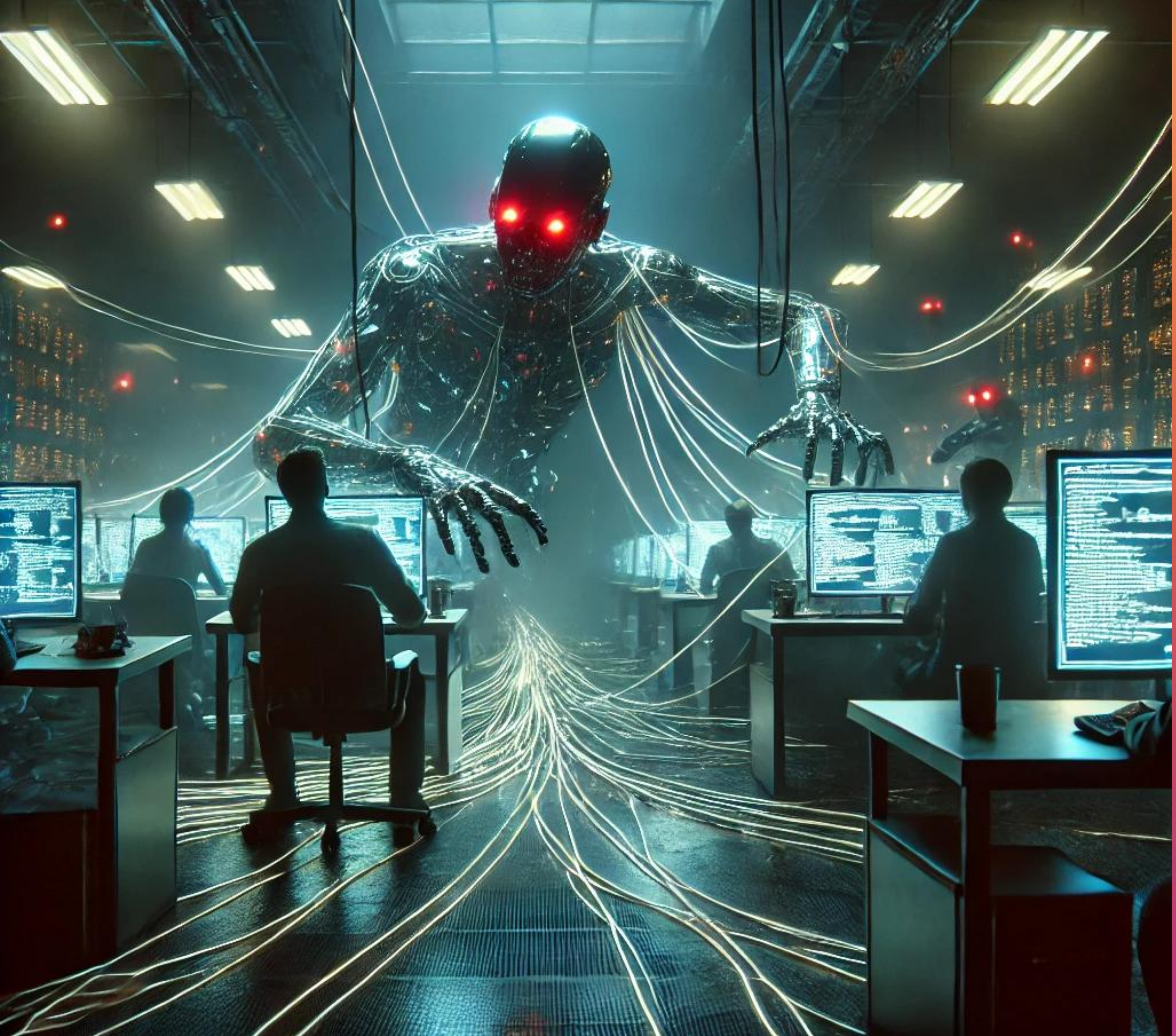
Kellyn Gorman

Engineer and Advocate

Kellyn.Gorman@red-gate.com

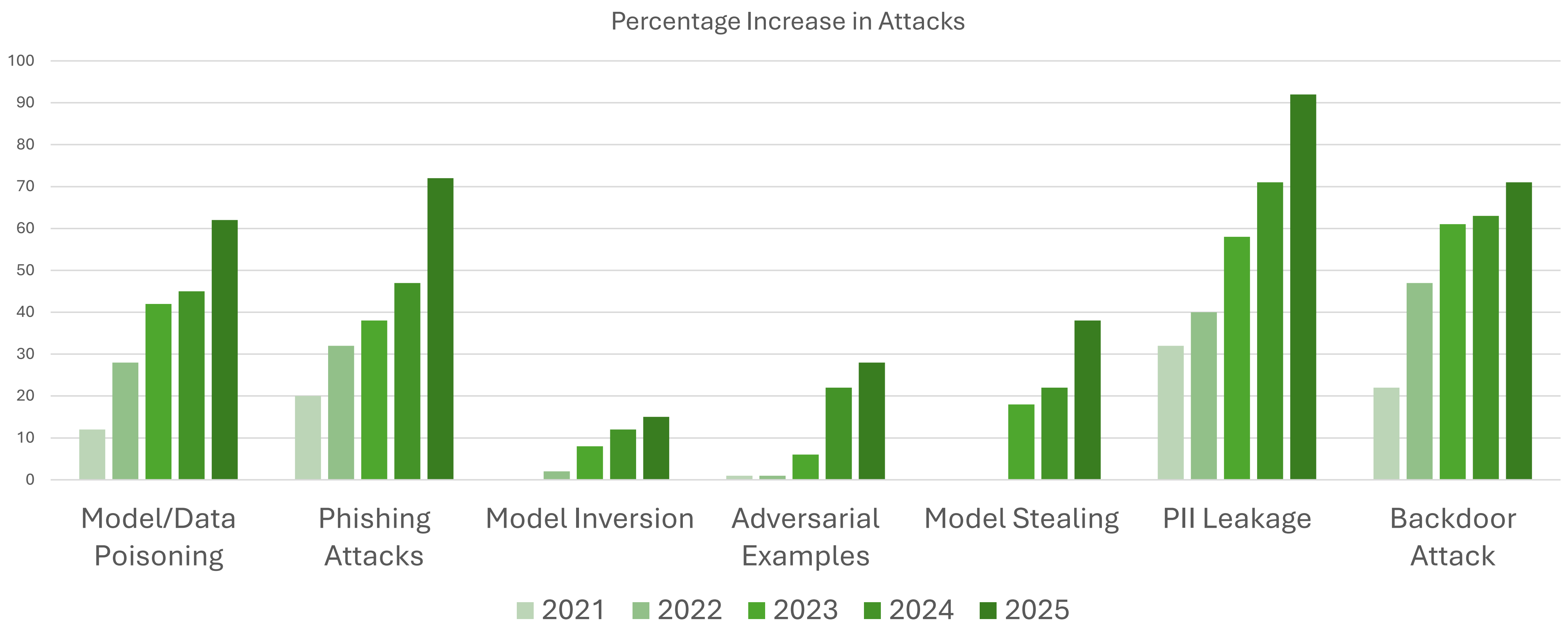
https://linkedin.com/in/kellyngorman

https://dbakevlar.com



AI is a Scary Place

AI Attacks are Increasing



Current Risks...

- Unauthorized Data Access & Exposure
- Hallucinations and Data Fabrication
- Lacking Governance
- Regulatory Compliance Challenges
- 3rd Party AI Dependencies

How Agentic AI has changed the game…

Generic RAG(Retrieval Augmented Gen) processes vs. Agentic RAG?

Not just returning a response but acting on a response.

How this can be hijacked?

https://www.harmonic.security/resources/from-payrolls-to-patents-the-spectrum-of-data-leaked-into-genai

Additional Risk with Agentic AI

- Intelligent Exploitation of Vulnerabilities
- Data Exfiltration and Evasion
- Large-Scale Data Scraping & Poisoning
- AI-Driven Social Engineering
- AI-Augmented Credential Stuffing and Brute Force Attacks
- Synthetic Identity and Fraudulent Transactions
- Insider Threat due to Shadow AI

Oh Yeah, One Other Thing…

First Story for the AI Hall of Shame...

Spring 2024

Loads Leasing Info data into Open-Source AI

This is a shadow AI project- no IT governance.

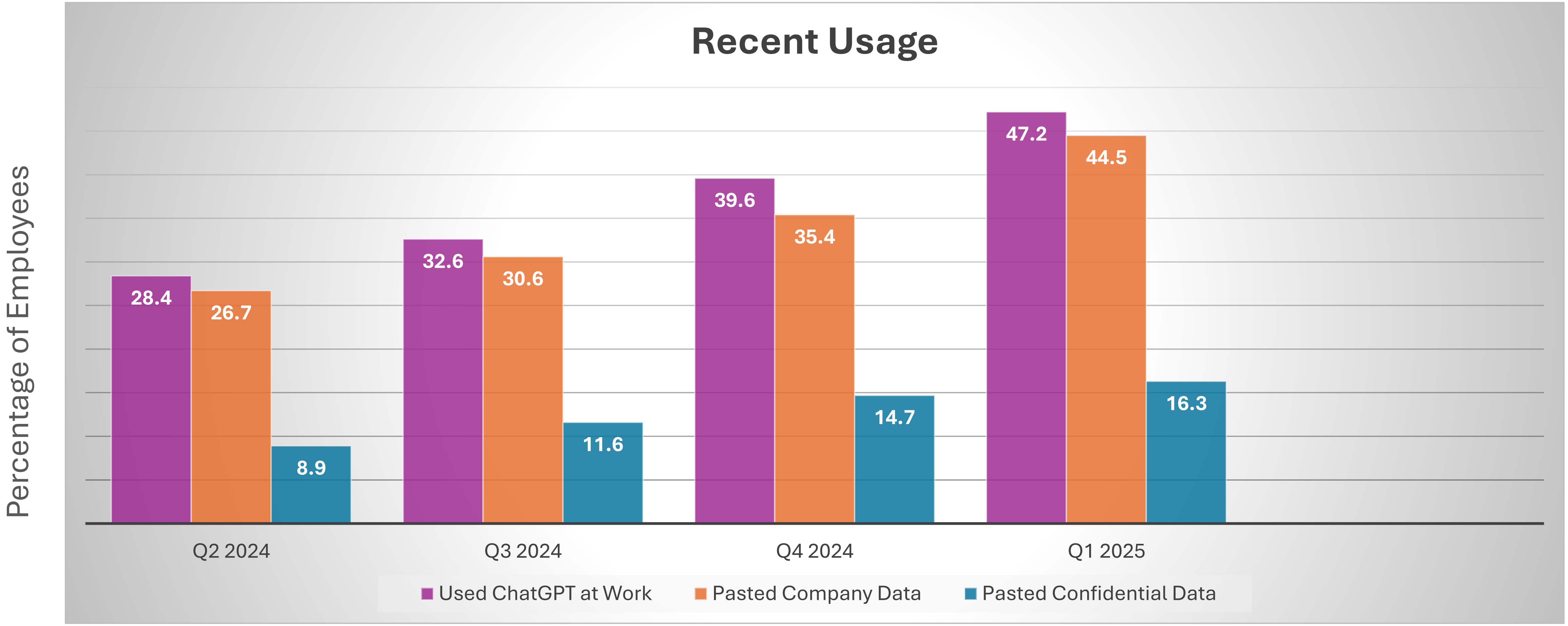
160K user and financial records now exposed.

It’s a Rare Occurrence, RIGHT??

- 8.5% of GenAI prompts included sensitive data in Q4 2024
- Over 45% included customer data, such as billing info, customer reports and authentication information.
- Over 25% was employee data, including payroll, PII and employment records.
- 7% was security policies and reports.
- 6% was proprietary source code and access keys.
- Over 60% was discovered in the free tier of ChatGPT

https://www.harmonic.security/resources/from-payrolls-to-patents-the-spectrum-of-data-leaked-into-genai

ChatGPT on its Own



Source: Cyberhaven.com

AI Hall of Shame: AI Confidential

- An AI-powered chatbot trained on internal documents at a major corporation was mistakenly exposed to the public. Employees, thinking it was private, began asking it questions about **confidential projects, financials, and even unreleased product details**—all of which were indexed by search engines before the company realized what had happened.

Lesson: AI chatbots should have strict access controls... unless you want your **roadmap leaked via Google Search.**

AI can be Brutal

- Logistics startup Flexport filed a lawsuit against Freightmate AI for using AI to steal source code and establishing a company.
- DarkSeek, which uses DeepSeek's flagship AI model to expose vulnerabilities and raises concerns about potential data breaches.
- **The average company is leaking sensitive data to ChatGPT and other publicly available AI solutions hundreds of times each week, with increases monthly of over 55%!**

Why Is this Happening?

AI models require large datasets for training

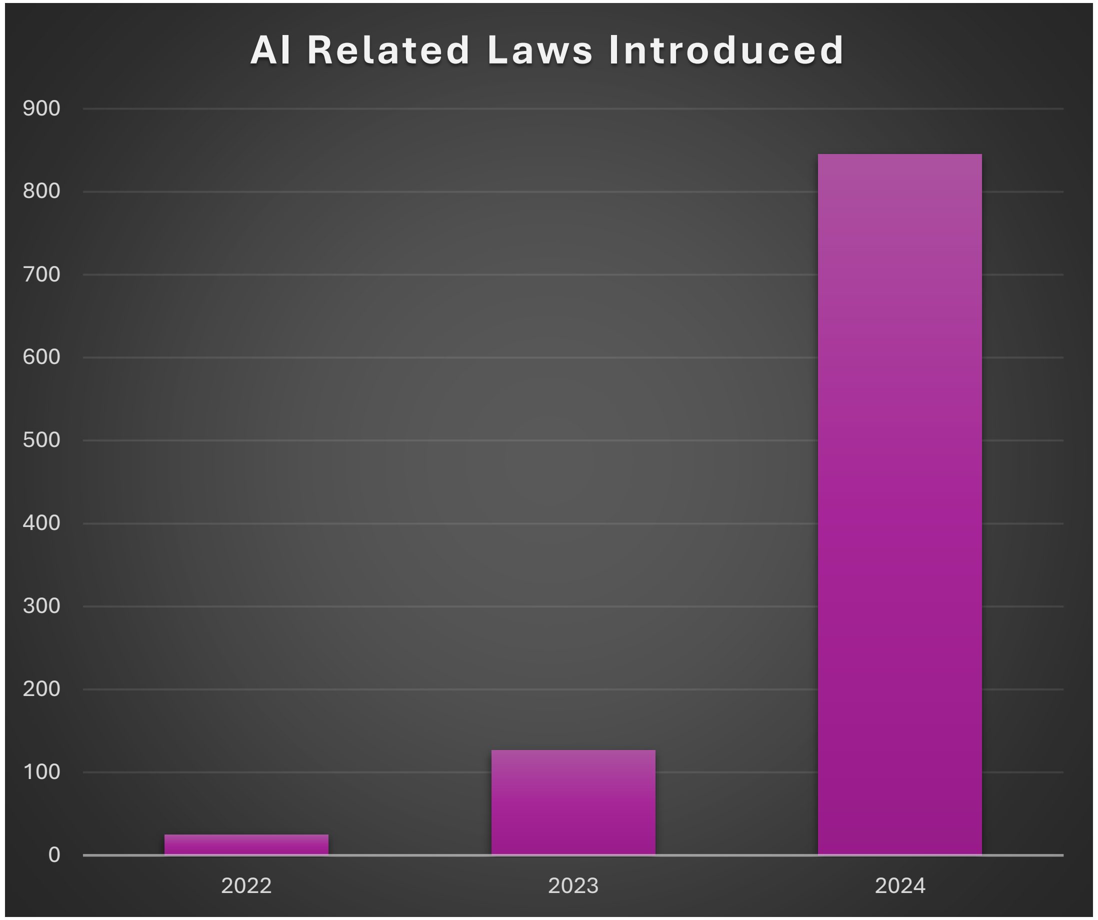
- Without proper controls, or when controls are over-ridden, PII, GDPR and other data can be breached by AI.
- Much is unintentional
- Leaked data via AI can expose organizations to breaches or prompt injection once discovered.

A Small Delay Does Decrease Risk

- EU Artificial Intelligence Act (AIA)
- National Artificial Intelligence Initiative Act of 2020 (US, H.R. 6216)
- AI in Government Act(US, H.R. 2575)
- Advancing American AI Act (US, S. 1353)

14 states passed legislation between 2016-2022

Over 3000% increase in AI related laws between 2022 and 2025



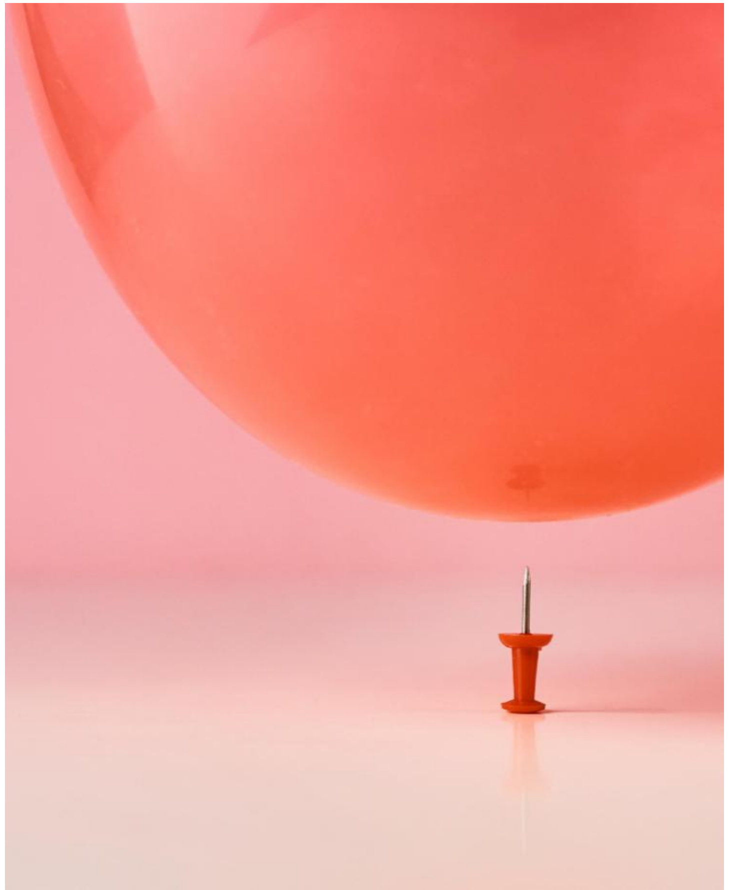
Model Memorization and Data Retention

AKA Persisting Sensitive Data as LLMs learn

If past interactions influence responses, bad actors might extract confidential insights.

Lack of understanding and use of ephemeral sessions to avoid feeding sensitive data into prompts, as well as be aware of retention policies.

Code risks around Python and SQL



AI Hall of Shame: The "Smart" Redaction Failure

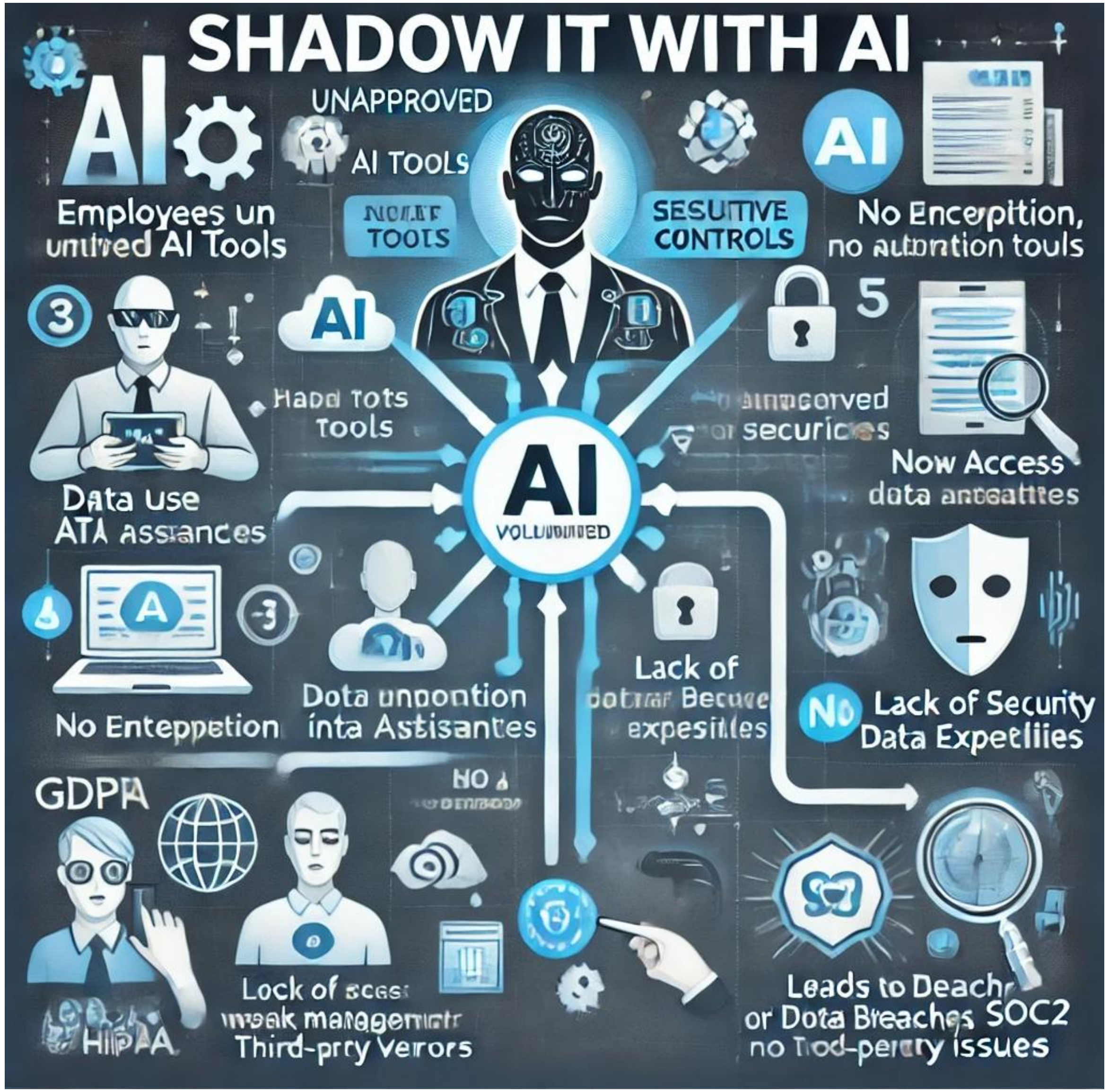
- A legal AI tool was used to automatically redact sensitive information in legal documents before public release. Unfortunately, the AI **only blacked out the text visually but** left it searchable. Curious users simply **copied and pasted the "redacted" sections** into Notepad and revealed everything.

Lesson: AI is smart, but **Ctrl+C, Ctrl+V is obviously way smarter.**

To Hallucinate or Fabricate – the Future of AI

- AI may become unusable in the next 3-5 years.
- How much by bad actors, how much by too much data feeding AI.
- Causes false or misleading information to be generated.
- Can be exploited for fraud, misinformation or regulatory non-compliance

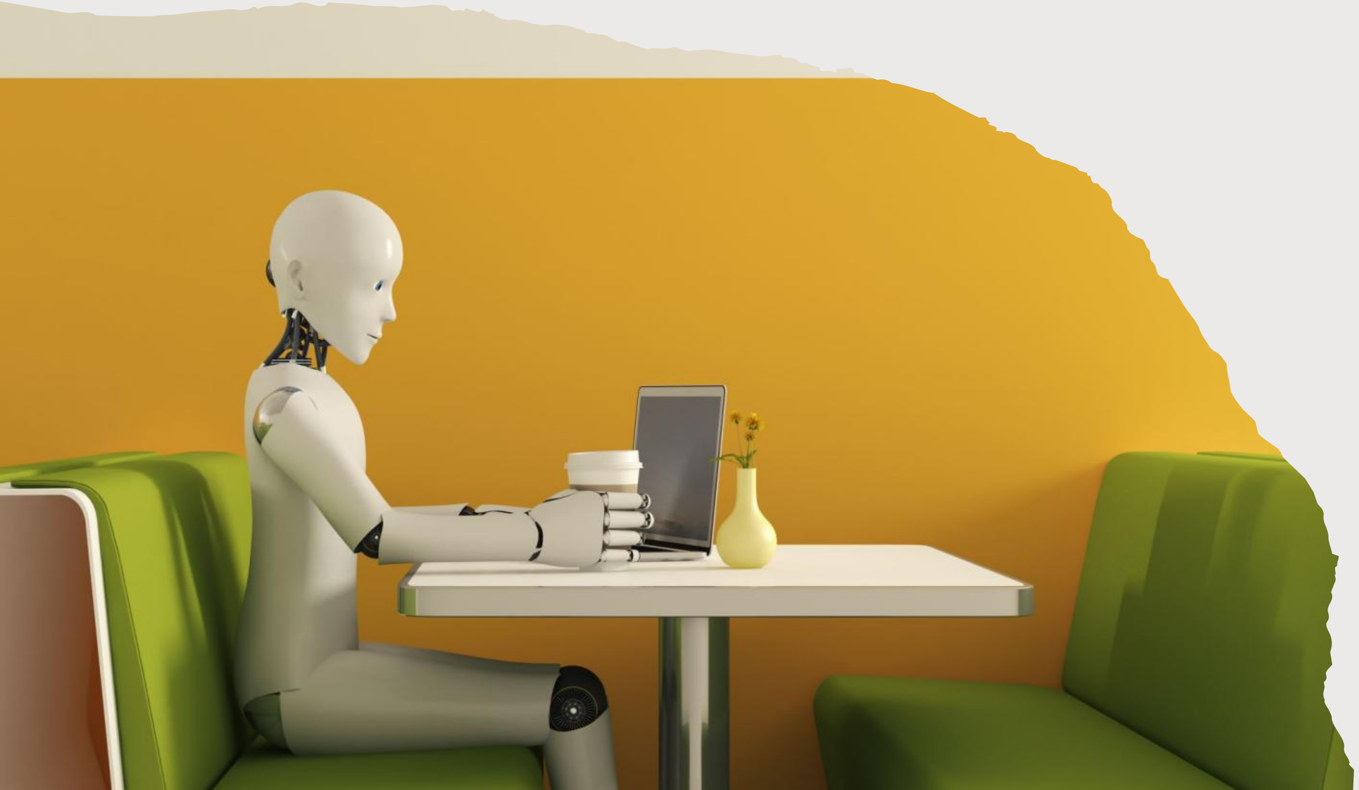
Does AI think we have a problem?



Shadow IT (SHADOW AI)

How many of the audience has had to manage a system that started out under someone's desk?

- AI is the new rogue production system.
- Employees or organizations deploying AI without IT or security oversight, i.e. shadow AI, can create
  - compliance risks
  - data leaks
  - security vulnerabilities



Solutions to these threats

- Strong AI Governance
- Encrypted Data Handling
- Strick Access Controls, including against Shadow AI
- Robust Monitoring
- Ongoing Compliance Audits

AI should enhance security, not be a mechanism to weaken it.

Establish AI Governance and Policies

- Define clear **AI usage policies** that outline which AI tools are approved and how they can be used.
- Require an **approval process** for ANY AI tool before employees can deploy them or use even open-source ones.
- Implement a **Responsible AI framework** to ensure ethical and compliant AI usage.

Explainability Is a Legal Concern Now

In industries like finance and healthcare, it's no longer optional for AI models to be a "black box."

- Laws like GDPR give people the right to an explanation if a decision is made about them by an algorithm.
- Even when sensitive fields are removed, AI models can infer private information based on patterns in the rest of the data.
- The EU AI Act and various U.S. state laws (like the California Privacy Rights Act) are introducing requirements for AI data governance, documentation, and risk mitigation. Compliance isn't just for humans anymore.

Educate the Organization

1

CONDUCT REGULAR TRAINING, (YES, MORE TRAINING!) ON THE RISKS OF SHADOW AI.

2

HAVE COMPLIANCE VIOLATIONS AND DATA SECURITY RISK ASSESSMENTS.

3

PROMOTE THE USE OF ONLY APPROVED AI TOOLS AND PROVIDE GUIDANCE FOR SAFE AI EXPERIMENTATION.

AI Hall of Shame: Too Polite Scam

- An AI-generated phishing scam attempted to trick users by pretending to be a financial institution. However, the model had been trained on polite corporate emails and produced phishing messages that **sounded too formal and apologetic**, leading recipients to **immediately suspect a scam**.

Lesson: AI-generated phishing attempts still can't replicate **the right amount of urgency and rudeness as humans.**

Enforce Access Controls and Monitoring

- Use a robust **Identify and Access Management (IAM)** to control who can access AI tools.
- Implement **Data Loss Prevention(DLP)** to monitor and restrict sensitive data sharing with AI systems.
- Deploy **SIEM(Security Information and Event Management)** tools to detect unauthorized usage.

AI Discovery Tools

ALONG WITH SHADOW IT DETECTION SOLUTIONS, LIKE PALO ALTO CORTEX XPANSE OR MS DEFENDER)

IMPLEMENT CLOUD SECURITY POSTURE MANAGEMENT(CSPM) TO TRACK AI TOOLS FROM CLOUD VENDORS, TOO.

Outside of Shadow AI…

3rd Party AI Dependencies

Lack of understanding and differences in 3rd party AI tools/providers, (OpenAI, Claude, CoPilot, Gemini, etc.)

All data is processed without a “black box” scenario so users can be accountable.

Clear understanding of the high risk of Shadow AI and public AI tools

AI Hall of Shame: AI Fell for Itself

- A fraud detection system for a bank used an AI voice model to authenticate customer service calls. Hackers got into the system and used the **same AI voice cloning tool** to impersonate a high-level executive, successfully authorizing large money transfers.

The most frustrating part? The AI **also mistakenly verified itself** when tested internally, leading to **weeks of confusion**.

Lesson: When AI can't tell the difference **between truth and consequence.**

AI Driven Attacks and Model Manipulation

Bad actors can manipulate or even poison AI models, (injecting misleading or incorrect data.)

May simply exploit model weaknesses

These can also extract confidential information.

Regulatory and Compliance Issues

AI decision making can lead to

biased outcomes	Non-compliant solutions	Unethical data usage

This can lead to potential legal risks, such as GDPR and CCPA violations.

Data Leakage

Synthetic Data Can Reduce Risk—If Used Correctly

Synthetically generated data that mimics real data without exposing sensitive information is a powerful tool in the war for data protection.

AI can enhance rules-based solutions.

A promising solution for training ML models without risking privacy—**but only if it's validated to avoid leaking patterns or poisoning production LLMs.**

AI Hall of Shame: Public Security Footage

A smart security system using facial recognition was set up to protect sensitive areas in an office building. However, the system's **cloud storage was misconfigured**, making all security footage publicly accessible.

The footage included:

- Employees **sneaking naps in empty meeting rooms**
- Executives **air-guitaring in their offices**
- Individuals **playing computer games**.

Lesson: AI can detect intruders, but it can't stop **IT from misconfiguring tech.**

To Combat All of This

- AI-driven threat detection and anomaly monitoring
- Level appropriate training for users, development, and even operations.
- Advanced testing before it gets to users
- Continual security awareness, heavily augmented with AI tools

Create Safer AI Adoption – Both Internal and Open-Source

- Have a list of sanctioned AI tools with clear security to prevent employees from seeking alternatives.
- Consider creating a centralized AI platform to safely perform AI experimentation for trusted individuals.
- Principle of Least Privileged works for AI just as it does for database technology.
- Monitor and sanitize Inputs and Outputs
- Utilize rights, privileges and access controls at every tier of AI.
- Enforce data classification, data masking and subsetting to limit risk in environments.

AI Hall of Shame: AI the Hacker

Security researchers have shown that LLMs like ChatGPT can be coaxed into writing polymorphic malware

- Wrote code that then rewrote itself to evade detection.
- This isn't a single breach, but the potential for AI-as-a-Service for hackers is REAL.
- Combine this with social engineering and it's a nightmares for datasec.

Lesson: We now live in an age where **AI might not just put us out of a job, but out of business.**

So Be Proactive

Because if you don’t talk to your organization about AI and Data Protection, who will?

Thank you!

Kellyn Gorman

Engineer and Advocate, Redgate